

Microsoft 365 Security Checklist

12 misconfigurations that show up in nearly every law firm audit

Use this checklist with your IT team or MSP. None of these fixes require new tooling or new budget. All twelve show up in client security audits, cyber insurance underwriting questions, and post-incident reviews. Walk through them once a quarter.

IDENTITY & ACCESS

01 Legacy authentication is still enabled

Basic auth for IMAP, POP, and SMTP bypasses MFA entirely. A single legacy printer left enabled is enough to create a credential-stuffing attack surface.

Check: Entra ID > Sign-in logs > filter for "Legacy authentication." **Fix:** Conditional Access policy blocking legacy auth org-wide.

02 MFA not enforced for every account, including service and break-glass

Partners, IT admins, and "temporary" service accounts are the most commonly exempted — and the most commonly compromised.

Check: Entra ID > Users > Per-user MFA report. **Fix:** Conditional Access requiring MFA for all users, with one excluded break-glass account stored in a sealed envelope.

03 Too many Global Administrators

Microsoft recommends fewer than five. Most firms have eight to fifteen, often including former IT staff who were never removed.

Check: Entra ID > Roles > Global Administrator. **Fix:** Reduce to ≤5, enable Privileged Identity Management for just-in-time elevation.

04 No Conditional Access policy for sensitive role sign-ins

Without geo-fencing, device-compliance, or risk-based controls, a stolen admin credential works from anywhere on earth.

Check: Entra ID > Conditional Access. **Fix:** Baseline policies for admin roles, risky sign-ins, and unmanaged devices.

DATA PROTECTION & SHARING

05 SharePoint and OneDrive external sharing set to "Anyone with the link"

A matter folder shared once for "easy collaboration" can surface in Google search months later. This is the single most common audit finding.

Check: SharePoint Admin Center > Sharing. **Fix:** Restrict to "New and existing guests" with verification codes; require sign-in for matter sites.

06 Sensitivity labels not deployed (or deployed but not enforced)

Labels without enforcement are decoration. Underwriters now ask whether labels actually drive encryption and access controls.

Check: Purview > Information Protection > Labels. **Fix:** Publish at least three labels (Public / Internal / Privileged) with encryption tied to Privileged.

07 DLP policies missing or stuck in audit-only mode

Audit-only logs an event after the data leaves the firm. It does not stop it.

Check: Purview > Data Loss Prevention > Policies. **Fix:** Move sensitive-data policies (SSN, financial, client matter IDs) from audit to enforce, with policy tips for users.

AUDITING & LOGGING

08 Mailbox audit logging incomplete

Microsoft's default action set is shorter than most people realize. MailItemsAccessed — the one you actually need for forensic investigation — is often not enabled.

Check: Get-Mailbox | Select Name, AuditEnabled, AuditOwner in Exchange Online PowerShell. **Fix:** Enable AuditOwner with MailItemsAccessed for all mailboxes.

09 Unified Audit Log enabled but never reviewed

Audit logs you do not review do not satisfy auditor expectations or insurer questions about "active monitoring."

Check: Purview > Audit search. **Fix:** Define a monthly review cadence for at least five activities (admin role changes, sharing changes, login failures, mailbox forwarding, app consents).

EMAIL & ENDPOINT

10 Anti-phishing policies running on default, not Strict preset

The default preset is intentionally permissive to avoid breaking new tenants. It is also intentionally weaker than what you actually want.

Check: Defender Portal > Email & Collaboration > Policies > Preset Security Policies. **Fix:** Apply Strict preset to all users; tune the few exceptions individually.

11 External auto-forwarding not blocked

A compromised mailbox quietly forwarding to an attacker's address is the single most common BEC pattern. Most firms still leave forwarding open.

Check: Defender Portal > Anti-spam outbound policy. **Fix:** Set automatic external forwarding to "Off" and alert on any new forwarding rules.

12 User consent for third-party apps left fully open

An innocent-looking OAuth consent prompt can hand an attacker persistent read access to every mailbox and SharePoint file the user can touch.

Check: Entra ID > Enterprise applications > Consent and permissions. **Fix:** Restrict user consent to verified publishers only; require admin approval for everything else.

Want a hands-on review of your tenant?

Watusoft runs a 5-day Microsoft 365 Security Posture Assessment for law firms. Findings, fixes, and a board-ready summary.

nikos@watusoft.com

watusoft.com · Jersey City, NJ